CASE STUDY

The Citrix NetScaler Zero-Days of September and October 2026 (CVE-2026-88771, CVE-2026-88772, CVE-2026-88779): A Case Study

A TeamStarWolf case study. Published 11 November 2026; every source checked as of that date.

Executive summary

The people who carried this one were the administrators of NetScaler ADC and NetScaler Gateway, the remote-access front door for governments, banks, hospitals and universities [25] [41] [43] (**Reported**). On the weekend of 26 and 27 September 2026, after rumours and private warnings from suppliers and CERTs, administrators took appliances offline before Citrix had said anything in public [32] [37] (**Reported**). In the Netherlands, central government cut its Citrix environments off from the internet and hospital patient portals went dark [39] [41] (**Reported**).

Citrix published bulletin CTX697096 on Sunday 27 September, covering eight CVEs and stating that exploits of two of them, CVE-2026-88771 and CVE-2026-88772, had been observed against unmitigated deployments [1] (**Confirmed**). CISA added both to its Known Exploited Vulnerabilities (KEV) catalog the same day, with a three-day deadline and forensic triage required [11] (**Confirmed**). A week later a third flaw, CVE-2026-88779, a denial of service on appliances configured for SAML, reached KEV on Sunday 4 October [2] [11] (**Confirmed**). Vendor researchers place the first related activity in August and exploitation from early September, about three weeks before disclosure [25] [26] (**Reported**).

Four findings stand out. Governments told owners to collect evidence before, or alongside, patching [13] [14] [17] [18] [22] (**Confirmed**). The appliance held the keys: in one Rapid7 case the attacker staged the appliance configuration for unauthenticated retrieval, exposing encrypted admin passwords, LDAP, RADIUS and TACACS bind secrets and TLS private keys [27] (**Reported**). The DoS flaw mattered more than its score: CISA says actors may use CVE-2026-88779 to force a reboot and speed execution of code already injected

through CVE-2026-88771 [13] (**Confirmed**). And the record disagrees with itself on the weakness of CVE-2026-88771 and on whether CVE-2026-88779 was exploited (Part 1) [1] [2] [7] [11] (**Confirmed**).

Key facts at a glance

Field	Value
Product	Customer-managed NetScaler ADC and NetScaler Gateway 14.1 and 13.1, including FIPS and NDcPP builds; Secure Private Access Hybrid deployments that use NetScaler [1] [2] (**Confirmed**)
CVEs	CVE-2026-88771 (unauthenticated RCE, CWE-20), CVE-2026-88772 (memory overflow, CWE-119, DTLS), CVE-2026-88779 (memory overflow to DoS, CWE-119, SAML) [1] [2] (**Confirmed**)
Fixed builds	14.1-73.37, 13.1-64.23, 14.1-73.37 FIPS, 13.1-37.279 for the September pair; 14.1-73.41, 13.1-64.28, 14.1-73.41 FIPS, 13.1-37.282 for CVE-2026-88779 [1] [2] (**Confirmed**)
First activity	Version fingerprinting from 21 Aug; CVE-2026-88772 activity from 4 Sep; CVE-2026-88771 attempts from 20 Sep [26] [27] (**Reported**)
KEV	CVE-2026-88771 and CVE-2026-88772 added 27 Sep, due 30 Sep, forensic triage Yes; CVE-2026-88779 added 4 Oct, due 7 Oct, forensic triage No [11] (**Confirmed**)
Actor	Not attributed in the Citrix, CISA, NCSC UK, CERT-EU, NCSC-NL, GTIG or Unit 42 records [25] [26] (**Confirmed** absence); Mandiant's Consulting CTO, quoted in the press, said suspected state-sponsored actors are likely behind the initial intrusions [46] (**Reported**)
Victims	Two confirmed by Rapid7; "dozens" per Mandiant; 78 and over 100 in single-source press figures [27] [43] [45] [46] (**Reported**)

Top recommendations

1. Run at least 14.1-73.41, 13.1-64.28, 14.1-73.41 FIPS or 13.1-37.282, which close CVE-2026-88779 as well as the September pair [1] [2] (**Confirmed**; supersession **Inferred** from version order), and apply the later build Citrix CTX697191 names for CVE-2026-107406 (CVSS 9.5, SAML), which this study did not open [20] (**Confirmed** that the fix exists).
2. Before updating an appliance that was internet-facing on an affected build, preserve a memory dump, a disk image and logs, and treat the device as possibly compromised [17] [18] [14] (**Confirmed** as NCSC-NL and CISA guidance).
3. Forward NetScaler logs off the box and keep at least a month of them, because local logs rotate [13] [18] (**Confirmed** as CISA and NCSC-NL guidance).
4. Where compromise is suspected, isolate, rebuild on current firmware, rotate every secret the appliance stored, revoke its certificates, and monitor for at least 90 days [4] [13] (**Confirmed** as Citrix and CISA guidance).
5. Never expose the management interface or NSIP to the internet, and restrict egress from the appliance [4] [25] (**Confirmed** for Citrix; GTIG's controls **Reported**).

Scope and method

This brief covers the September bulletin CTX697096 and the October bulletin CTX697174, from the first related scanning in August 2026 to KEV catalog 2026.11.10. It sets the August flaw CVE-2026-19490 and the later CVE-2026-107406 beside them as context. Earlier NetScaler waves (CVE-2019-19781, Citrix Bleed, CVE-2025-5777) are covered elsewhere in the library and linked in Part 3. Tradecraft is described at advisory level: no request formats, paths, indicators or exploit steps. Times are UTC unless a source gives another zone.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: Citrix bulletins, the CVE, NVD and KEV records, and government or national CERT advisories
Reported	A single security vendor's research or press coverage, not independently confirmed by a primary
Demonstrated	Shown in a reproducible public artifact (watchTowr's root-cause analyses), or by this study's own check of the library's ATT&CK, CWE, CAPEC and D3FEND data
Inferred	This study's own reasoning from cited facts, labelled where it appears

A note on CERT-EU numbering: Security Advisory 2026-010, published 19 August 2026, covers CVE-2026-19489 and CVE-2026-19490 from Citrix CTX696939; the September zero-days are CERT-EU 2026-014 [15] [16] (**Confirmed**). Citrix's own blog posts for both bulletins could not be opened, so their content is known only as press quotes them [34] [35] (**Reported**).

Part 1: what happened

Date (2026)	Event	Sources	Grade
19 Aug	Citrix CTX696939 fixes CVE-2026-19490, an authentication bypass (CWE-288, CVSS 4.0 9.3), with no exploitation statement; CERT-EU 2026-010 the same day	[3] [16]	Confirmed
21 to 22 Aug	Version-fingerprinting requests to more than 100 systems; not confirmed exploitation	[26]	Reported
Early Sep to 27 Sep	GTIG dates the CVE-2026-88772 campaign from at least early September; Unit 42 sees DTLS web shell activity 4 to 24 Sep, files staged on appliances, infrastructure rotated daily, and the last pre-disclosure request at 01:54 on 27 Sep	[25] [26]	Reported
9 Sep	KEV adds CVE-2026-19490, due 12 Sep, forensic triage Yes; its exploitation was reportedly first seen on 3 Sep	[11] [31]	Confirmed (3 Sep Reported)
10 Sep	The NetScaler CNA reserves CVE-2026-88771 and CVE-2026-88779 (both 07:14) and CVE-2026-88772	[5] [6] [7]	Confirmed
20 to 21 Sep	Rapid7 sees the earliest CVE-2026-88771 attempts (20 Sep); a three-stage command-injection web shell against a single US organization (21 Sep)	[26] [27]	Reported
24 Sep	GreyNoise records a failed CVE-2026-88771 attempt at 07:32; Rapid7 sees a web shell at a victim; the Citrix patch watchTowr later analysed is dated this day	[27] [28] [37]	Reported
26 Sep	watchTowr publicly confirms the rumours; NCSC-NL sends a TLP:AMBER pre-notification citing a European partner CERT and exploitation at multiple Citrix customers	[32] [37]	Reported
27 Sep (Sunday)	Citrix CTX697096; CVE records published 16:02 and 16:09; NCSC-NL NCSC-2026-0394 v1.0.0 at 16:55; NVD at 17:16; CERT-EU 2026-014 (17:40, zone not stated); KEV adds both CVEs, due 30 Sep; CISA alerts and a 15:58 EDT bulletin	[1] [5] [6] [8] [11] [12] [13] [14] [15] [17]	Confirmed
27 Sep	Dutch central government disconnects its Citrix environments; Amphia and Elisabeth-TweeSteden patient portals unavailable; Health-ISAC alerts members; an insurer warns customers	[36] [39] [41] [43]	Reported
28 Sep	NCSC UK alert; Canada's AV26-965; HKCERT "Extremely High Risk" bulletin; watchTowr's CVE-2026-88771 root-cause analysis; an ASD ACSC critical alert is reported (page not opened)	[21] [22] [23] [24] [29] [38]	Confirmed (watchTowr Demonstrated; ACSC Reported)
29 Sep	GTIG and Mandiant publish; watchTowr's CVE-2026-88772 analysis; mass scanning follows the public proof of concept	[25] [30] [45]	Reported (watchTowr Demonstrated)
30 Sep	KEV due date; NCSC-NL v1.0.1 adds scan-script and IoC guidance; Unit 42 brief	[11] [17] [18] [26]	Confirmed (Unit 42 Reported)
2 Oct	CISA adds a SIGMA rule resource to its alert; admins report forced reboots of appliances already on 14.1-73.37	[13] [34]	Confirmed (reboots Reported)

Date (2026)	Event	Sources	Grade
3 to 4 Oct	Citrix CTX697174 for CVE-2026-88779 (3 Oct PST); on Sunday 4 Oct the CVE record is published 02:35, NVD 04:16, KEV adds it, due 7 Oct, and NCSC-NL issues NCSC-2026-0399 at 13:19	[2] [7] [10] [11] [19]	Confirmed
5 Oct	Citrix offers Global Deny List signatures as interim mitigation; watchTowr reproduces CVE-2026-88779	[35] [48]	Reported
9 Oct	NCSC-NL NCSC-2026-0410 covers CVE-2026-107406 (SAML memory overflow, CVSS 9.5); CISA's alert adds CVE-2026-88779 and CVE-2026-107406	[13] [20]	Confirmed

Discrepancies in the record

- **Which weakness.** Citrix and NVD give CWE-20 for CVE-2026-88771; the KEV entry lists CWE-119, and its notes link the NVD page of CVE-2026-88772 [1] [8] [11] (**Confirmed**). The CNA record for CVE-2026-88772 carries no CWE, while Citrix and NVD give CWE-119 [1] [6] [9] (**Confirmed**).
- **Which score.** CVE-2026-88772 is 9.5 on the CNA's CVSS 4.0 and 8.1 on NVD's CVSS 3.1; CVE-2026-88771 is 9.5 and 9.8 [8] [9] (**Confirmed**).
- **Was CVE-2026-88779 exploited.** The Citrix bulletin has no exploitation statement [2], but the CVE record's SSVC entry reads exploitation active and KEV lists it [7] [11] (**Confirmed**); Citrix's blog, as quoted, speaks of targeted attacks leading to DoS [34] [50] (**Reported**).
- **One reservation day for three flaws.** All three CVEs were reserved on 10 September [5] [6] [7] (**Confirmed**). A reservation date alone does not show when Citrix understood each flaw (**Inferred**).

Part 2: the technical record

CVE	Class (Citrix)	Precondition	CVSS	SSVC (CISA ADP)
CVE-2026-88771	RCE from improper input validation, unauthenticated; CWE-20	All deployments, default configuration	4.0: 9.5; 3.1 (NVD): 9.8, AV:N/AC:L/PR:N/UI:N	Active, automatable, total [5]
CVE-2026-88772	Memory overflow leading to RCE or DoS; CWE-119	DTLS enabled, the default for VPN vServers	4.0: 9.5 (AC:H); 3.1: 8.1 (AC:H)	Active, not automatable, total [6]
CVE-2026-88779	Memory overflow leading to DoS; CWE-119	Appliance configured as SAML SP or IdP	4.0: 8.7, availability only; 3.1: 7.5, A:H only	Active, automatable, partial [7]

Sources: [1] [2] [5] to [10] (**Confirmed**).

The other six CVEs in CTX697096 are request smuggling (CVE-2026-88773, 9.3), a policy bypass (CVE-2026-88774, 7.0), three memory overflows (CVE-2026-88775 to CVE-2026-88777, 8.8) and TCP ISN prediction (CVE-2026-88778, 8.8); none is marked exploited [1] (**Confirmed**). Citrix directs deployments affected by CVE-2026-88778 to enable Enhanced ISN Generation, and CERT-EU gives the same advice [1] [15] (**Confirmed**). Citrix-managed cloud services and Adaptive Authentication were upgraded by Cloud Software Group [1] (**Confirmed**). Citrix credits JPMorgan Chase, Bishop Fox and watchTowr in the

CVE-2026-88779 bulletin [2] (**Confirmed**).

What attackers did, at advisory level. GTIG identified exploitation of CVE-2026-88772 reaching root-level access, followed by custom web shells, web-server configuration changes for persistence, a tunneler used for internal reconnaissance, credential harvesting and access-log scrubbing [25] (**Reported**). It names two custom tools: WHIPSHOT, a PHP web shell that hides command and control in native HTTP headers, and SLAPSHOT, a Python tunneler; in at least one intrusion the actor tunnelled in for manual reconnaissance and credential theft [25] (**Reported**). GreyNoise describes a playbook of a root shell, a hidden PHP web shell behind a fake stylesheet path and a web-server restart [28] (**Reported**). Rapid7 describes the configuration theft noted above and a separate web shell [27] (**Reported**). watchTowr's analyses reproduced root-level command execution for CVE-2026-88771 and code execution from the DTLS memory overflow for CVE-2026-88772 [29] [30] (**Demonstrated**).

CVE-2026-88779 in practice. Admins on 14.1-73.37 reported repeated forced reboots; one saw crafted SAML usernames carrying download attempts with no confirmed execution, and a researcher reported a patched honeypot running a downloaded binary [34] (**Reported**). Rapid7 says repeated attempts crash the SAML service and the sixth crash reboots the appliance [27] (**Reported**). watchTowr says one crafted request knocks an appliance offline and suspects the flaw was used to speed CVE-2026-88771 exploitation [48] (**Reported**), which matches CISA's hedged statement [13] (**Confirmed**). Remote code execution through CVE-2026-88779 is not established by any primary (**Inferred** from [2] [7] [11]).

Part 3: who and why

No Citrix, CISA, NCSC UK, CERT-EU, NCSC-NL, GTIG or Unit 42 record opened for this study attributes the activity to a named group, cluster or country; GTIG and Unit 42 refer only to "the threat actor" [25] [26] (**Confirmed** as an absence across those records). Citrix did not attribute the CVE-2026-88779 activity [35] (**Reported**).

The suspicions are on record as suspicions. Mandiant's Consulting CTO said advanced and suspected state-sponsored actors are likely behind the initial targeted intrusions using CVE-2026-88772 [46] (**Reported**). A researcher judged the initial activity probably nation-state aligned espionage [44] (**Reported**). watchTowr's CEO said no attribution had been made public and no clear target trend had emerged [47] (**Reported**). After the public proof of concept, deception sensors recorded attempts within minutes and exploitation turned opportunistic [45] (**Reported**), so later intrusions need not share an actor with the September ones (**Inferred**).

History explains why both readings circulate. A Tenable engineer estimated that about two-thirds of NetScaler-targeting activity over seven years involved APT groups and one-third ransomware groups [44] (**Reported**). KEV marks known ransomware use for CVE-2023-3519, CVE-2023-4966 (Citrix Bleed, in Chronicle 2023 and The Ransomware Ecosystem) and CVE-2025-5777 (in Chronicle 2025), and Unknown for all three 2026 CVEs here [11] (**Confirmed**). The library already records APT41 exploiting CVE-2019-19781 in APT41: The Public Record, Fox Kitten (Pioneer Kitten) using Citrix in Threat Actors: Iran, Citrix in PRC advisories in Threat Actors: China, the 2019 to 2020 wave in Chronicle 2019 and Chronicle 2020, Citrix Bleed in Chronicle 2023 and The Ransomware Ecosystem, and CVE-2025-5777 in Chronicle 2025 [53] (**Confirmed**). None of that lineage is evidence about who ran the 2026 campaign (**Inferred**).

Part 4: impact and response

Victims. GTIG says organizations in government, financial services, technology, education, and legal and professional services in North America and Europe were likely impacted [25] (**Reported**). Rapid7 confirmed two compromised organizations [27]; Mandiant's CTO spoke of dozens, adding telecommunications [46]; Arctic Wolf researchers were reported to count at least 78 targeted organizations, a figure its own blog does not carry [43]; and one researcher tracked over 100 victims, each with a unique web shell, with fewer than 10% of exposed hosts patched [45] (all **Reported**). These counts are unreconciled single-source figures [43] (**Inferred**). Exposure counts of more than 20,000 (Shadowserver), about 42,000 (Censys) and 50,277 (Unit 42) measure reachability, not compromise [26] [43] [45] (counts **Reported**; the reading **Inferred**).

Disruption in the Netherlands. The Ministry of the Interior said central government disconnected its Citrix environments, so remote civil servants could not log in [39] (**Reported**). Z-CERT advised hospitals to take measures such as disabling the systems [40] (**Reported**). Amphia and Elisabeth-TweeSteden had patient portals unavailable over the weekend; spokespeople said only outside-in access was affected and care continued, and Frisius MC switched off some services as a precaution [41] (**Reported**). As of 28 September only Dutch organizations had publicly reported disruption [42] (**Reported**). This was self-inflicted downtime as a defensive choice, not a reported breach (**Inferred** from [39] [41]).

The vendor. Citrix told the press it had recently identified the vulnerabilities and immediately released new software, and did not answer when it learned of exploitation [36] (**Reported**). The underwriting-security vice president of a cyber insurer that notified potentially vulnerable customers before official confirmation called Citrix's 36-hour public silence "unconscionably irresponsible" [36] (**Reported**). For CVE-2026-88779, Citrix said, as quoted by the press, that it had not identified an impact on the integrity of customer data, and customers already on the September builds who met the SAML precondition had to upgrade again [34] (**Reported**).

Government record. CISA's alert says reports and partner threat intelligence confirm active exploitation globally, and its bulletin advises checking indicators of compromise before patching and preserving evidence because updates may lose forensic visibility [13] [14] (**Confirmed**). CISA's KEV alert ties the entries to BOD 26-04, which sets expectations for checking whether a system was compromised before the patch [12] (**Confirmed**). NCSC-NL rated likelihood and damage high and advised treating systems that were reachable from the internet before the update as possibly compromised [17] (**Confirmed**); its alert says CVE-2026-88771 gives attackers full control of the gateway and direct access to the internal network [18] (**Confirmed**). NCSC UK's priority actions are isolate and replace, investigate with IoCs, report, patch, and use NetScaler Console File Integrity Monitoring [21] [22] (**Confirmed**). Canada, HKCERT and CERT-EU issued advisories on 27 and 28 September [15] [23] [24] (**Confirmed**).

KEV context (catalog 2026.11.10)	Value
Citrix entries	27, of which six were added in 2026
2026 additions before this event	CVE-2026-3055 (30 Mar), CVE-2026-8452 (26 Aug), CVE-2026-19490 (9 Sep)
This event	CVE-2026-88771 and CVE-2026-88772 (27 Sep), CVE-2026-88779 (4 Oct), all ransomware use Unknown

KEV context (catalog 2026.11.10)	Value
Not listed	CVE-2026-107406

Source: [11] (**Confirmed**). A former CISA vulnerability-response lead notes that Sunday KEV additions had one precedent and that Citrix's discovery-to-disclosure window for NetScaler fell to 17 days in 2026 after it set up a NetScaler CNA [33] (**Reported**).

Part 5: the defender and vulnerability-management view

The dates do most of the arguing. Fingerprinting from 21 August and exploitation from early September, against disclosure on 27 September, mean local logs had likely rotated before most owners began to hunt [25] [26] (**Inferred**). The advice centres on off-box logs, memory capture and secret rotation rather than the patch alone [4] [13] [17] (**Confirmed** as guidance); this study reads the log-rotation risk as the reason (**Inferred**). Unit 42 warns that patching will not remove persistence already established [26], and Citrix acknowledged its IoCs might fail to identify actual compromises [44] (**Reported**).

Control	Where it meets the record
Patch to the latest build, not only the September ones	Customers on 14.1-73.37 that met the SAML precondition had to upgrade again [2] [34]; CVE-2026-107406 followed on 9 Oct [20]
Capture memory, disk and logs before updating, and keep a month of logs off-box	NCSC-NL and CISA [13] [14] [18]; SIEM hunting advised because the Console script needs unrotated logs [44] (**Reported**)
Interim blocks where patching lags	Disable DTLS or block inbound UDP/443 for CVE-2026-88772, restrict management and NSIP, restrict egress, halt HA config sync until both nodes are validated [25] (**Reported**); Global Deny List signatures for CVE-2026-88779 [35] (**Reported**)
Rebuild and rotate	Rotate every secret stored on the appliance including key-encryption keys and certificates; reset Gateway and AAA users; investigate connected systems [4] [13]
Order the queue with KEV and SSVC	KEV set three-day deadlines for all three CVEs and required forensic triage for the September pair; SSVC marked CVE-2026-88771 automatable with total impact [5] [11]

A behavioural sensor labelled the 24 September attempt malicious within seconds, before any CVE signature existed [28] (**Reported**): detection that keys on what an appliance does, not on a CVE id, was the kind that could work during the zero-day window (**Inferred**).

What is overstated and what is understated

- **Overstated:** victim counts of "dozens", 78 and over 100 are single-source and unreconciled with Rapid7's two confirmed cases [27] [43] [45] [46]; exposure totals of 20,000 to 50,277 are not compromise counts (**Inferred**). "State-sponsored" is a suspicion from one firm's executive, not an attribution [46] (**Reported**). Calling CVE-2026-88779 a third remote-code-execution zero-day goes beyond Citrix, NVD and KEV, which describe a DoS [2] [10] [11] (**Confirmed**).

- **Understated:** the three-week head start for attackers, which outlived local log retention [26] (**Inferred**); the theft of bind secrets and TLS keys, which survives any patch [27] (**Reported**); the possible role of the DoS flaw as an accelerator for code already injected [13] (**Confirmed** as CISA's hedged statement); and the record conflicts in Part 1 [1] [11] (**Confirmed**), which can send scanners and dashboards keyed on one feed in different directions (**Inferred**).

MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0 Enterprise, CWE, CAPEC and D3FEND. Names and tactics come from the library's `data/attack/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl` and `data/weaknesses/` files, and every linked page was checked in the `mitre/` tree [52] (**Demonstrated**). No source names ATT&CK ids for this activity, so every id below is this study's mapping of a described behavior (**Inferred**). No industrial system is involved, so no ATT&CK for ICS techniques apply.

Groups, software and campaigns

No source attributes the activity, so no group is bound [25] [26] (**Confirmed**). ATT&CK has no software object for WHIPSHOT or SLAPSHOT and no campaign object for this activity [52] (**Demonstrated**). Two groups are related through earlier NetScaler exploitation, not bound:

Object	ATT&CK id	Relationship to this record
APT41	G0096	Exploited CVE-2019-19781, per APT41: The Public Record. Lineage only
Fox Kitten	G0117	Pioneer Kitten exploited Citrix, per Threat Actors: Iran. Lineage only

ATT&CK Enterprise techniques

ID	Name	Tactic(s)	Dated event or report	Sources
T1595.002	Vulnerability Scanning	Reconnaissance	Version fingerprinting of more than 100 systems, 21 to 22 Aug; wide-scale scanning after disclosure and after the public proof of concept (29 Sep)	[26] [45]
T1587.001	Malware	Resource Development	Custom WHIPSHOT and SLAPSHOT tools (GTIG, 29 Sep)	[25]
T1190	Exploit Public-Facing Application	Initial Access	Exploits of CVE-2026-88771 and CVE-2026-88772 observed by Citrix (27 Sep); activity from early Sep	[1] [11] [13] [25]
T1059.004	Unix Shell	Execution	Root shell in the playbook GreyNoise saw on 24 Sep; command-injection web shell (21 Sep)	[26] [28]
T1059.006	Python	Execution	SLAPSHOT, a Python tunneler (GTIG, 29 Sep)	[25]
T1505.003	Web Shell	Persistence	DTLS web shells 4 to 24 Sep; three-stage web shell 21 Sep; web shell at a Rapid7 victim 24 Sep; WHIPSHOT	[25] [26] [27] [49]
T1036.005	Match Legitimate Resource Name or Location	Stealth	PHP web shell hidden behind a fake stylesheet path (24 Sep)	[28]
T1105	Ingress Tool Transfer	Command and Control	Files staged on appliances 4 to 24 Sep; SAML usernames carrying download attempts (2 Oct)	[26] [34]
T1071.001	Web Protocols	Command and Control	WHIPSHOT hides command and control in native HTTP headers (29 Sep)	[25]
T1572	Protocol Tunneling	Command and Control	Actor tunnelled in through SLAPSHOT for manual internal reconnaissance (29 Sep)	[25]
T1552.001	Credentials In Files	Credential Access	Configuration exposing encrypted admin passwords and LDAP, RADIUS and TACACS bind secrets (Rapid7, 28 Sep); credential harvesting (GTIG)	[25] [27]
T1552.004	Private Keys	Credential Access	TLS private keys in the staged configuration (Rapid7)	[27]
T1074.001	Local Data Staging	Collection	Appliance configuration staged for unauthenticated retrieval (Rapid7)	[27]
T1070	Indicator Removal	Stealth	Access-log scrubbing (GTIG, 29 Sep)	[25]
T1499.004	Application or System Exploitation	Impact	CVE-2026-88779 crashes and forced reboots (2 to 4 Oct); KEV DoS entry (4 Oct); CISA on reboot as an accelerator (9 Oct)	[11] [13] [27] [34]

Fit notes (**Inferred**): T1059.006 rests on GTIG's description of SLAPSHOT as a Python tool rather than an observed interpreter run. GTIG's web-server configuration changes for persistence are covered under T1505.003, since the sources do not describe them further. No technique is bound for the internal reconnaissance, which no source details, or for exploit acquisition, since no source says whether the actor built or bought the exploits. T1070 is bound at the parent level because the access logs are web-server logs, not the system logs that T1685.006 covers.

CWE and CAPEC

CWE	Name	Where it is assigned	Sources
CWE-20	Improper Input Validation	CVE-2026-88771: Citrix, CNA record and NVD	[1] [5] [8]
CWE-119	Improper Restriction of Operations within the Bounds of a Memory Buffer	CVE-2026-88772 (Citrix, NVD), CVE-2026-88779 (Citrix), and CVE-2026-88771 in KEV only	[1] [2] [9] [11]
CWE-288	Authentication Bypass Using an Alternate Path or Channel	CVE-2026-19490, the August precursor	[3]
CWE-444	Inconsistent Interpretation of HTTP Requests	CVE-2026-88773 (Citrix), not exploited	[1]

CAPEC entries the library relates to these CWEs or techniques that meet the record [52]:

CAPEC	Name	Via	Where it meets the record
CAPEC-88	OS Command Injection	CWE-20	watchTowr's pre-auth command injection analysis and Unit 42's command-injection web shell [26] [29] (**Inferred** fit)
CAPEC-100	Overflow Buffers	CWE-119	The DTLS and SAML memory overflows [1] [2]
CAPEC-650	Upload a Web Shell to a Web Server	T1505.003	The web shells in Part 2 [25] [26] [27] [28]
CAPEC-268	Audit Log Manipulation	T1070	Access-log scrubbing [25]
CAPEC-542	Targeted Malware	T1587.001	WHIPSHOT and SLAPSHOT [25]

The request-smuggling flaw CVE-2026-88773 carries CWE-444 (Inconsistent Interpretation of HTTP Requests) in the Citrix bulletin, which the library relates to CAPEC-33 HTTP Request Smuggling, but it is not marked exploited, so it is not bound [1] [52] (**Confirmed** for the CWE; the decision not to bind is **Inferred**). The library's CAPEC relations for CWE-288 (CAPEC-127, CAPEC-665) do not meet the record [52] (**Demonstrated**). See the CWE Reference and CAPEC Reference.

D3FEND countermeasures

D3FEND countermeasure	Techniques the library maps it to (from this study)	Where it meets the record
Inbound Traffic Filtering	T1190	Block inbound UDP/443 or disable DTLS; origin restriction in front of the gateway [25] [51]
Network Traffic Signature Analysis	T1190, T1105, T1572	WAF and IPS signatures for CVE-2026-88771 and CVE-2026-88772 [49] [51]
Outbound Traffic Filtering	T1572, T1105, T1071.001	GTIG's egress restriction [25]
File Integrity Monitoring	T1505.003, T1036.005, T1074.001, T1552.001	NetScaler Console File Integrity Monitoring [21] [22]

CTX694799 and CISA's recovery steps correspond to Credential Rotation, Credential Revocation, Certificate Rotation, Session Termination, Restore Software and Restore Configuration, which the library does not relate to these techniques [4] [13] [25] [52] (**Inferred**). See the D3FEND Reference.

Navigator layer

The study's techniques are saved as an ATT&CK Navigator layer, `navigator/library-layers/citrix-netscaler-september-2026.json` (open in Navigator), listed on the Navigator layers page. It is pinned to ATT&CK v20, domain `enterprise-attack`. A score of 75 means a vendor bulletin, CVE record or government advisory describes the behavior; 50 means a security vendor's report describes it; 25 means a capability or an inexact fit rather than an observed act. Each comment names the event and the source numbers.

Cross-cutting themes

- **The edge appliance is a standing exposure.** Citrix has 27 KEV entries, six from 2026 alone [11] (**Confirmed**). See the Edge Device Security Reference for Citrix Bleed and AA23-325A, and Change Healthcare 2024 for a Citrix portal without MFA as the way in [53].
- **Patching is the start of the response, not the end.** The same lesson ran through CVE-2019-19781 in Chronicle 2019 and returns here with forensic triage written into KEV [11] [53] (**Inferred**).
- **Disclosure timing is now a fight in public.** Rumours, private CERT warnings and an insurer's notices moved faster than the vendor bulletin [32] [36] [37] (**Reported**).
- **A low score can hide a role in the chain.** CVE-2026-88779 scores availability only, yet CISA ties it to code injected through CVE-2026-88771 [7] [13] (**Confirmed**).
- **Automated exploitation follows the public proof of concept.** Scanning began within minutes of the public proof of concept [45] (**Reported**). See AI Threats in the Cybersecurity Industry for claims about AI tooling against an earlier NetScaler flaw [53].

Sources

All sources were opened on 11 November 2026.

#	Source	URL	Opened	Grade
1	Citrix, CTX697096, NetScaler ADC and NetScaler Gateway security bulletin for CVE-2026-88771 to CVE-2026-88778, 27 Sep 2026	support.citrix.com/external/article/CTX697096	2026-11-11	Confirmed
2	Citrix, CTX697174, security bulletin for CVE-2026-88779, 3 Oct 2026 (PST)	support.citrix.com/external/article/CTX697174	2026-11-11	Confirmed
3	Citrix, CTX696939, security bulletin for CVE-2026-19489 and CVE-2026-19490, 19 Aug 2026	support.citrix.com/external/article/CTX696939/...	2026-11-11	Confirmed
4	Citrix, CTX694799, steps to take if NetScaler ADC is suspected to be compromised	support.citrix.com/external/article/CTX694799/...	2026-11-11	Confirmed
5	CVE Program record CVE-2026-88771 (CNA NetScaler)	cveawg.mitre.org/api/cve/CVE-2026-88771	2026-11-11	Confirmed
6	CVE Program record CVE-2026-88772 (CNA NetScaler)	cve.org/CVERecord?id=CVE-2026-88772	2026-11-11	Confirmed
7	CVE Program record CVE-2026-88779 (CNA NetScaler)	cveawg.mitre.org/api/cve/CVE-2026-88779	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
8	NVD, CVE-2026-88771	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-88771	2026-11-11	Confirmed
9	NVD, CVE-2026-88772	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-88772	2026-11-11	Confirmed
10	NVD, CVE-2026-88779	services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-88779	2026-11-11	Confirmed
11	CISA, Known Exploited Vulnerabilities catalog JSON, version 2026.11.10	cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json	2026-11-11	Confirmed
12	CISA, CISA Adds Two Known Exploited Vulnerabilities to Catalog, 27 Sep 2026	cisa.gov/news-events/alerts/2026/09/27/cisa-adds-two-...	2026-11-11	Confirmed
13	CISA, Critical Zero-Day Vulnerabilities Exploited in Citrix NetScaler ADC, Gateway, 27 Sep 2026, updated 2 Oct and 9 Oct 2026	cisa.gov/news-events/alerts/2026/09/27/critical-zero-day-...	2026-11-11	Confirmed
14	CISA, bulletin of the same title, 27 Sep 2026, 15:58 EDT	content.govdelivery.com/accounts/USDHSCISA/bulletins/42cc465	2026-11-11	Confirmed
15	CERT-EU, Security Advisory 2026-014, Critical Vulnerabilities in Citrix NetScaler ADC and Gateway, 27 Sep 2026	cert.europa.eu/publications/security-advisories/2026-014/	2026-11-11	Confirmed
16	CERT-EU, Security Advisory 2026-010, 19 Aug 2026	cert.europa.eu/publications/security-advisories/2026-010/	2026-11-11	Confirmed
17	NCSC-NL, advisory NCSC-2026-0394, v1.0.0 27 Sep 2026, v1.0.1 30 Sep 2026 (HTML and CSAF)	advisories.ncsc.nl/2026/ncsc-2026-0394.html	2026-11-11	Confirmed
18	NCSC-NL, alert on the NetScaler ADC and Gateway vulnerabilities, 27 Sep 2026, updated 30 Sep 2026	ncsc.nl/alerts/kwetsbaarheden-in-citrix-netscaler-...	2026-11-11	Confirmed
19	NCSC-NL, advisory NCSC-2026-0399, 4 Oct 2026	advisories.ncsc.nl/2026/ncsc-2026-0399.html	2026-11-11	Confirmed
20	NCSC-NL, advisory NCSC-2026-0410, 9 Oct 2026	advisories.ncsc.nl/2026/ncsc-2026-0410.html	2026-11-11	Confirmed
21	NCSC UK, Exploitation of vulnerabilities affecting Citrix NetScaler ADC and Citrix NetScaler Gateway, 28 Sep 2026	ncsc.gov.uk/news/exploitation-of-vulnerabilities-...	2026-11-11	Confirmed
22	NCSC UK, the same alert as PDF, 28 Sep 2026	ncsc.gov.uk/sites/default/files/2026-09/...	2026-11-11	Confirmed
23	Canadian Centre for Cyber Security, Citrix security advisory AV26-965, 28 Sep 2026	cyber.gc.ca/en/alerts-advisories/citrix-security-advisory-av26-965	2026-11-11	Confirmed
24	HKCERT, Citrix Products Multiple Vulnerabilities, 28 Sep 2026	hkcert.org/security-bulletin/citrix-products-multiple-vulnerabilities_20260928	2026-11-11	Confirmed

#	Source	URL	Opened	Grade
25	Google Threat Intelligence Group and Mandiant, Defending Against Active Exploitation of Citrix NetScaler ADC and Gateway Appliances, 29 Sep 2026	cloud.google.com/blog/topics/threat-intelligence/defending-against-...	2026-11-11	Reported
26	Unit 42, threat brief on the NetScaler zero-days, 30 Sep 2026, updated to 8 Oct 2026	unit42.paloaltonetworks.com/netscaler-zero-days-exploited/	2026-11-11	Reported
27	Rapid7, ETR: zero-day exploitation of Citrix NetScaler ADC and Gateway, 28 Sep 2026, updated to 19 Oct 2026	rapid7.com/blog/post/etr-zero-day-exploitation-of-citrix-...	2026-11-11	Reported
28	GreyNoise, Swarming against Citrix 0-day exploitation, 28 Sep 2026	greynoise.io/blog/swarming-against-citrix-0-day-exploitation	2026-11-11	Reported
29	watchTowr Labs, root-cause analysis of CVE-2026-88771, 28 Sep 2026	labs.watchtowr.com/oh-look-the-foot-gun-went-off-again-...	2026-11-11	Demonstrated
30	watchTowr Labs, root-cause analysis of CVE-2026-88772, 29 Sep 2026	labs.watchtowr.com/here-we-go-again-...	2026-11-11	Demonstrated
31	SecurityWeek, report on CVE-2026-19490 exploitation, Sep 2026	securityweek.com/critical-netscaler-vulnerability-exploited-in-attacks/	2026-11-11	Reported
32	SecurityWeek, report on Citrix confirming two zero-days after admins pulled the plug, 28 Sep 2026	securityweek.com/citrix-confirms-2-netscaler-zero-days-...	2026-11-11	Reported
33	SecurityWeek, column on what the NetScaler zero-days say about the new normal, 27 Oct 2026	securityweek.com/this-is-fine-...	2026-11-11	Reported
34	BleepingComputer, report on Citrix patching an exploited NetScaler SAML zero-day, 4 Oct 2026	bleepingcomputer.com/news/security/citrix-patches-netscaler-saml-...	2026-11-11	Reported
35	CSO Online, report on Citrix warning of an actively exploited NetScaler flaw, 5 Oct 2026	csoonline.com/article/4230642/...	2026-11-11	Reported
36	CyberScoop, report on delayed disclosure of the Citrix zero-days, 28 Sep 2026	cyberscoop.com/citrix-zero-days-delayed-disclosure/	2026-11-11	Reported
37	Dark Reading, report on the NetScaler zero-days, 29 Sep 2026	darkreading.com/vulnerabilities-threats/netscaler-zero-days-chaos-citrix	2026-11-11	Reported
38	Infosecurity Magazine, report on Citrix patching critical zero-days, Sep 2026	infosecurity-magazine.com/news/citrix-patches-critical-zero-days/	2026-11-11	Reported
39	NOS, report on hospitals and Citrix, 27 Sep 2026	nos.nl/artikel/2632818-...	2026-11-11	Reported
40	DutchNews, report on hospitals blocking access to patient records, 28 Sep 2026	dutchnews.nl/2026/09/hospitals-block-access-...	2026-11-11	Reported
41	Omroep Brabant, report on the hospital outages, 27 Sep 2026	omroepbrabant.nl/nieuws/6028801/...	2026-11-11	Reported
42	SDxCentral, report on NetScaler bugs and critical sectors in Europe, 28 Sep 2026	sdxcentral.com/news/netscaler-bugs-bring-...	2026-11-11	Reported
43	Cybersecurity Dive, what we know about the NetScaler exploitation, 30 Sep 2026	cybersecuritydive.com/news/exploitation-citrix-netscaler-what-we-know/831780/	2026-11-11	Reported

#	Source	URL	Opened	Grade
44	Help Net Security, report on the NetScaler RCE zero-days, 28 Sep 2026	helpnetsecurity.com/2026/09/28/citrix-netscaler-rce-zero-days-...	2026-11-11	Reported
45	Help Net Security, report on exploitation escalating into mass attacks, 29 Sep 2026	helpnetsecurity.com/2026/09/29/netscaler-zero-day-exploitation-...	2026-11-11	Reported
46	Help Net Security, report on CVE-2026-88772 exploitation, 30 Sep 2026	helpnetsecurity.com/2026/09/30/cve-2026-88772-...	2026-11-11	Reported
47	The Register, report on custom malware in the Citrix zero-day attacks, 29 Sep 2026	theregister.com/security/2026/09/29/...	2026-11-11	Reported
48	The Register, report on further NetScaler zero-day reports, 5 Oct 2026	theregister.com/security/2026/10/05/...	2026-11-11	Reported
49	Check Point Research, threat intelligence report, 5 Oct 2026	research.checkpoint.com/2026/5th-october-threat-intelligence-report/	2026-11-11	Reported
50	Check Point Research, threat intelligence report, 12 Oct 2026	research.checkpoint.com/2026/12th-october-threat-intelligence-report/	2026-11-11	Reported
51	Cloudflare, post on protecting NetScaler gateways, 19 Oct 2026	blog.cloudflare.com/protect-your-netscaler-gateway/	2026-11-11	Reported
52	TeamStarWolf library data: `data/attack/technique_profiles.jsonl`, `groups.jsonl`, `software.jsonl`, `campaigns.jsonl`, `technique_to_d3fend.jsonl` and `superseded_by.jsonl` (ATT&CK v20.0), `data/weaknesses/cwe.jsonl` and `capec.jsonl`, and the `mitre/` page tree	github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	2026-11-11	Demonstrated
53	TeamStarWolf case studies and references on Citrix: APT41, Iran, China, Chronicle 2019, 2020, 2023 and 2025, The Ransomware Ecosystem, Change Healthcare, AI Threats, Edge Device Security	/case-studies/README.md	2026-11-11	Confirmed

Not opened, so not cited as sources: Citrix's community blog posts for both bulletins (bot challenge), the ASD ACSC alert (timeout), Citrix CTX697191 for CVE-2026-107406, Arctic Wolf's figure of 78 (its own blog does not carry it), and the Shadowserver and Censys dashboards behind the press exposure counts. Rapid7's separate technical analysis of 19 October was not checked.

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- APT41: The Public Record, Threat Actors: Iran, Threat Actors: China, Chronicle 2019, Chronicle 2020, Chronicle 2023, Chronicle 2025, The Ransomware Ecosystem, Change Healthcare 2024, AI Threats in the Cybersecurity Industry, The Year 2026 in Intrusions, Timeline
- Other 2026 edge-appliance studies: The Ivanti Connect Secure zero-day chain, The Cisco Catalyst SD-WAN authentication bypass
- Threat Actors, Malware Families, Notable Incidents
- CVE Reference, CWE Reference, CAPEC Reference, D3FEND Reference
- Edge Device Security Reference, Citrix NetScaler platform page
- Vulnerability Management Reference, Vulnerability Prioritization Reference
- Groups (lineage only): G0096 APT41, G0117 Fox Kitten
- Techniques: T1595.002 Vulnerability Scanning, T1587.001 Malware, T1190 Exploit Public-Facing Application, T1059.004 Unix Shell, T1059.006 Python, T1505.003 Web Shell, T1036.005 Match Legitimate Resource Name or Location, T1105 Ingress Tool Transfer, T1071.001 Web Protocols, T1572 Protocol Tunneling, T1552.001 Credentials In Files, T1552.004 Private Keys, T1074.001 Local Data Staging, T1070 Indicator Removal, T1499.004 Application or System Exploitation
- CAPEC: CAPEC-88, CAPEC-100, CAPEC-650, CAPEC-268, CAPEC-542
- Navigator layers, including this study's layer, citrix-netscaler-september-2026.json
- The Team Star Wolf Intelligence Hub
- All case studies